

Pessoas e acesso

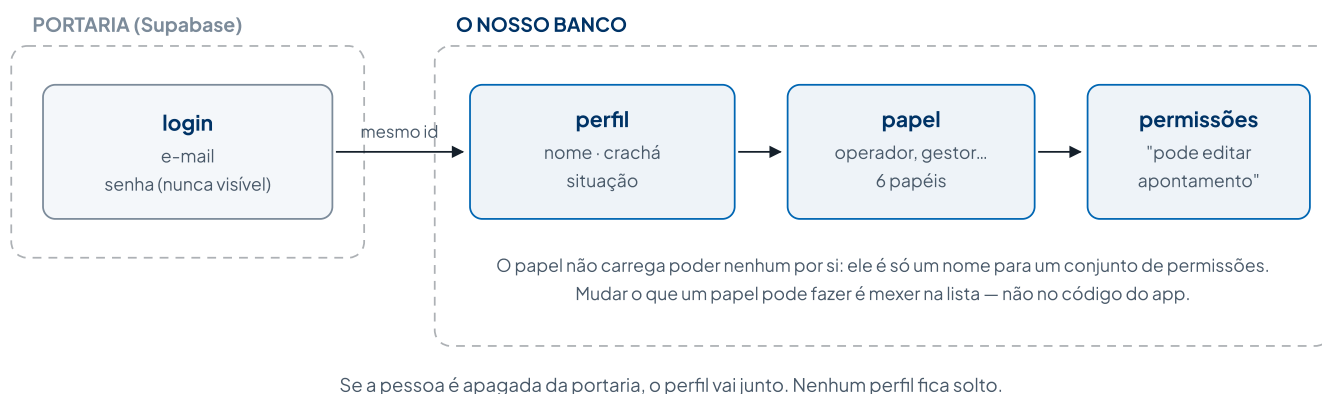
Quem entra, quem aprova a entrada, e como o banco decide o que cada pessoa pode fazer — sem depender do app para isso.

1. Duas fichas para a mesma pessoa

Analogia: a **portaria** guarda o e-mail e a senha; o **RH** guarda o nome, o crachá e o cargo. São dois arquivos diferentes sobre a mesma pessoa, ligados por um número.

A portaria é uma área do Supabase que não é nossa: ninguém, nem o administrador, consegue ler senha de lá. O que o nosso banco guarda é só a ficha do RH — nome, crachá, perfil, situação. As duas se ligam pelo identificador da pessoa.

Vantagem: a senha nunca passa pelo nosso código nem aparece em nenhuma tabela nossa. Custo: recuperar senha, confirmar e-mail e trocar senha usam as ferramentas do Supabase, e cada uma dessas telas precisa ser feita (a de "esqueci minha senha" **ainda não existe**).



Três saltos: **login** → **perfil** → **papel** → **permissões**. Toda regra do sistema pergunta pela permissão, nunca pelo nome do papel.

2. Por que permissão e não cargo

Analogia: é a diferença entre a porta que abre **para o chaveiro** e a porta que abre **para quem tem a chave**. Se um dia o preparador também precisar abrir, no primeiro caso alguém muda a fechadura; no segundo, entrega uma chave.

Foi a decisão **D33**. A alternativa era escrever "se o papel for operador, então...". Funciona, mas cada mudança de política vira mudança de código, e cada papel novo obriga a revisar todas as regras.

Com permissão, existe uma lista — "apontar", "editar o próprio apontamento", "editar qualquer apontamento", "gerenciar usuários", e assim por diante — e cada papel recebe as suas. A regra no banco pergunta: *esta pessoa tem esta permissão?*

Trade-off: ganha flexibilidade e uma política que se lê numa tabela em vez de caçar no código. Custa um salto a mais em toda verificação, e uma lista que precisa ser mantida com cuidado — permissão errada na lista é porta aberta.

3. Os seis papéis

PAPEL	O QUE FAZ NO DIA A DIA
operador	Aponta a produção do seu turno e corrige o que ele mesmo lançou, por 24 h. Vê só os próprios apontamentos
preparador	Vê tudo e corrige apontamento de qualquer pessoa
distribuidor	Além do acima, mexe no calendário e faz alteração em lote
gestor	Metas, relatórios e aprovação de cadastro
administrador	Tudo, inclusive papéis e permissões
TV	Só lê o painel. Não aponta, não edita, não vê usuário

A conta da TV existe porque o painel na parede fica logado o dia inteiro, sem ninguém olhando. Se ela tivesse poder de apontar, qualquer pessoa que passasse pelo teclado teria também.

4. O cadastro não entra sozinho

Analogia: é o visitante que preenche a ficha na recepção e espera. A ficha existe, o crachá não foi liberado.

Quem se cadastra fica com situação **pendente**. Nesse estado a pessoa consegue entrar no sistema mas não recebe permissão nenhuma — na prática, vê uma tela dizendo que o acesso aguarda aprovação. O gestor ou o administrador aprova, e só então o papel passa a valer.

SITUAÇÃO	O QUE ACONTECE
pendente	Cadastro feito, sem permissões. Aparece na lista de aprovação
ativo	Uso normal, com as permissões do papel
bloqueado	Entrada recusada no login, com mensagem própria

Detalhes que valem saber: o **crachá** não pode repetir, e é o que a fábrica usa para identificar a pessoa; ao se cadastrar, o sistema sempre **desconecta** em seguida, para a pessoa não achar que já entrou (decisão D20); a primeira pessoa aprovada tem de ser criada à mão como administradora, senão não haveria quem aprovasse ninguém.

5. Onde a regra é aplicada

Analogia: a diferença entre **esconder o botão** e **trancar a porta**. O app esconde; o banco tranca.

Todas as regras deste caderno vivem **dentro do banco**, em políticas que acompanham cada tabela. Isso significa que mesmo alguém que passe por fora do app — com a chave pública, uma ferramenta qualquer — continua limitado ao que o seu papel permite. O app esconde botões por conveniência; a garantia está embaixo.

Limite honesto: a chave pública do projeto vai no navegador de qualquer pessoa — é o desenho normal do Supabase e não é segredo. A proteção real não é a chave, são as políticas. Por isso elas foram testadas: 23 verificações que tentam, de propósito, fazer cada papel passar do seu limite.

6. O que falta aqui

Esqueci minha senha

Não existe. Hoje, quem perde a senha precisa de outra conta ou de intervenção no painel do Supabase. É o item mais urgente deste caderno.

Trocar a própria senha

Também não existe tela. A infraestrutura do Supabase já suporta; falta a parte visível.

Limite de e-mails

O projeto de testes só envia poucos e-mails por hora. Criar muitas contas seguidas dá erro — agora com mensagem clara em vez de erro técnico.

Um login por navegador

Abrir duas abas com contas diferentes não funciona: o Supabase guarda uma sessão por navegador. A aba antiga agora percebe a troca e avisa, em vez de mostrar dado errado.

Próximo caderno: **avisos, auditoria e segurança** — o registro do que aconteceu e quem fez.